

DDOS Attack and its Mitigation – Simulation in GNS3

Summary: A private LAN network comprising of hundreds of end devices and several servers in DMZ is protected by Cisco ASA (Firewall). In the internet the most commonly found network attack is to take down enterprise resources by DDOS (Distributed Denial of Service) attack either on Servers (which will impact hundreds of end users) or on the network resources like routers itself.

In this practical simulation we will analyze how a DOS attack happens on web server placed in DMZ from the internet via traffic flooding, and how we can fine tune ASA to mitigate and stop further attacks on the network.

Devices used:

- a) Attacker PC – Windows XP – Service Pack3
- b) Web server (Simulated in GNS3)
- c) ASA Version 8.4 (Simulated in GNS3)
- d) Cisco Router – 3750 (Simulated in GNS3)
- e) Ethernet Switch (Simulated in GNS3)

Software used:

- a) Wireshark (version – 1.6.8)
- b) GNS3 (Version – 0.8.3.1)
- c) Net tools (Version - 5.0.7)

Step 1:

Install Windows XP (SP3) on a virtual machine, (in this case we have used Oracle's virtual box). This step is to make sure that the system may not get infected with the virus which comes packed with hacking and network monitoring tools.

Furthermore, as we are using a virtual operating system, we will be sure that, our actual working pc may not be affected with our experiments.

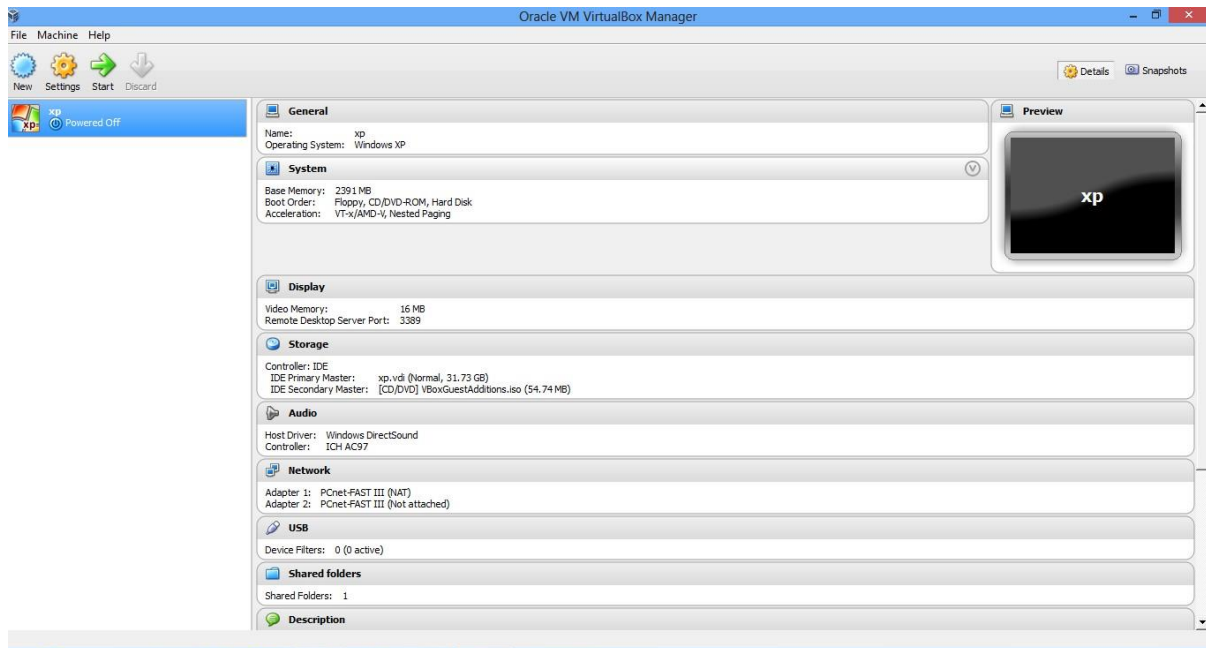


Image 1: The Oracle virtual box manager showing windows XP(SP3) Step

2:

Install GNS3 (Graphical Network Simulator) inside the virtual XP.

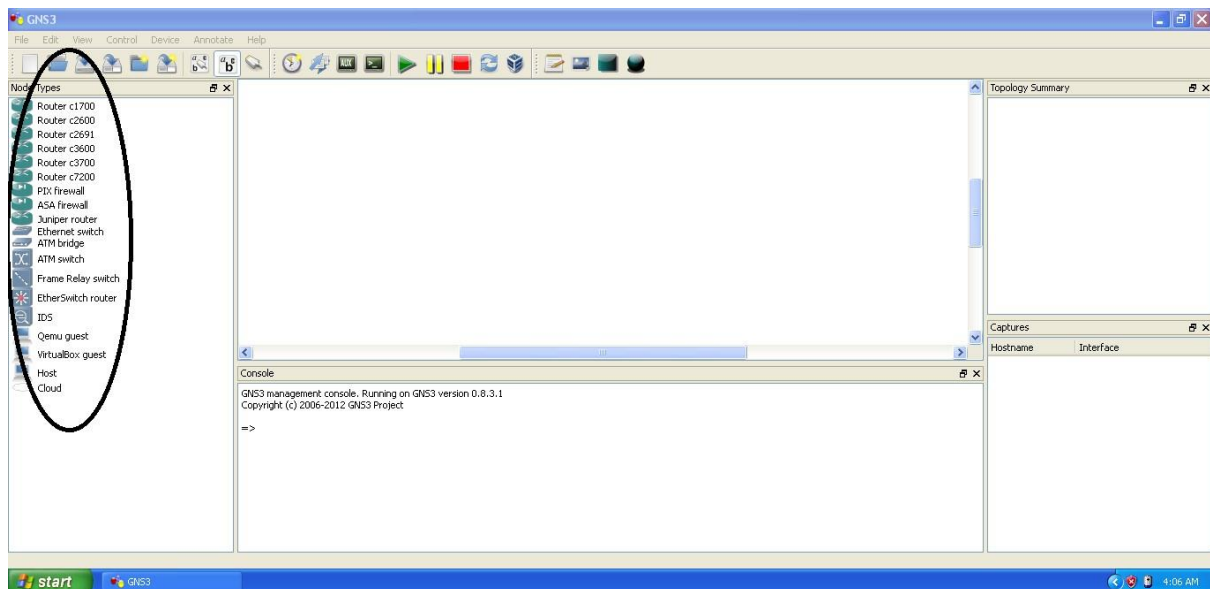


Image 2: Image of GNS3 installed and running on virtual XP

In the above image, the circle shows the virtual network appliances, i.e. routers, switches, bridges, firewall and IPS/IDS are available for simulation using GNS3.

In most cases GNS3 comes with Putty, Wireshark bundled. In case if GNS3 doesn't have Wireshark, we have to install Wireshark on the virtual XP machine too.

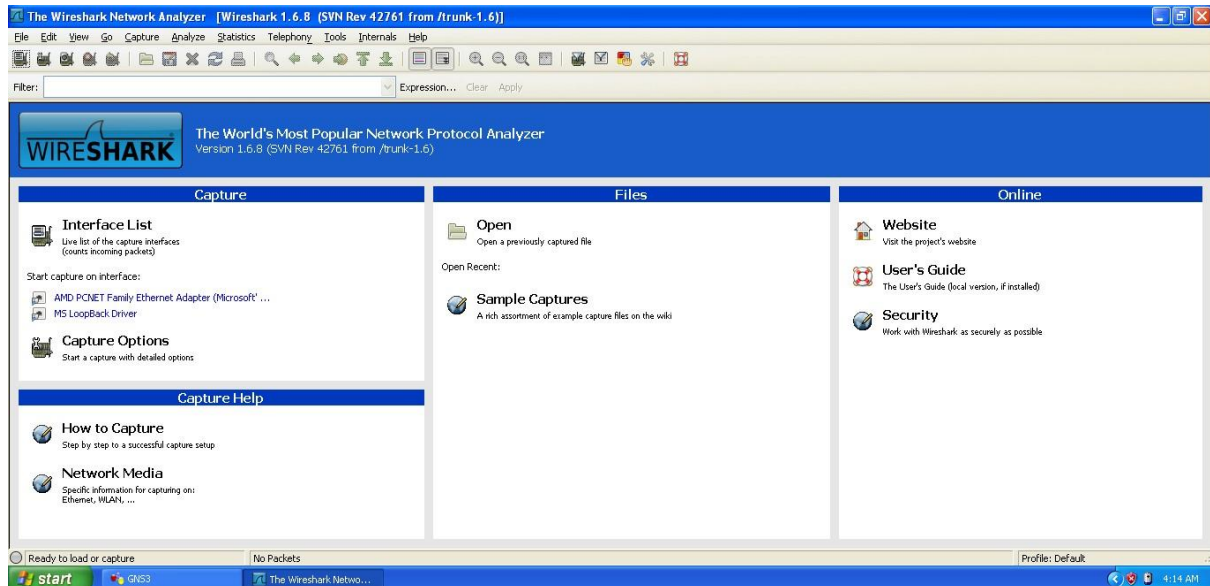


Image 3: This image represents the Wireshark software, installed and running on virtual XP.

Step 3: Install Net Tools (Network monitoring & Hacking Tool) in the same virtual XP machine. This tool can be used to monitor Network activities and can be used as a potential hacking tool. In this simulation we will use this tool to flood the server with icmp packets, which will lead to a DOS attack on the server.

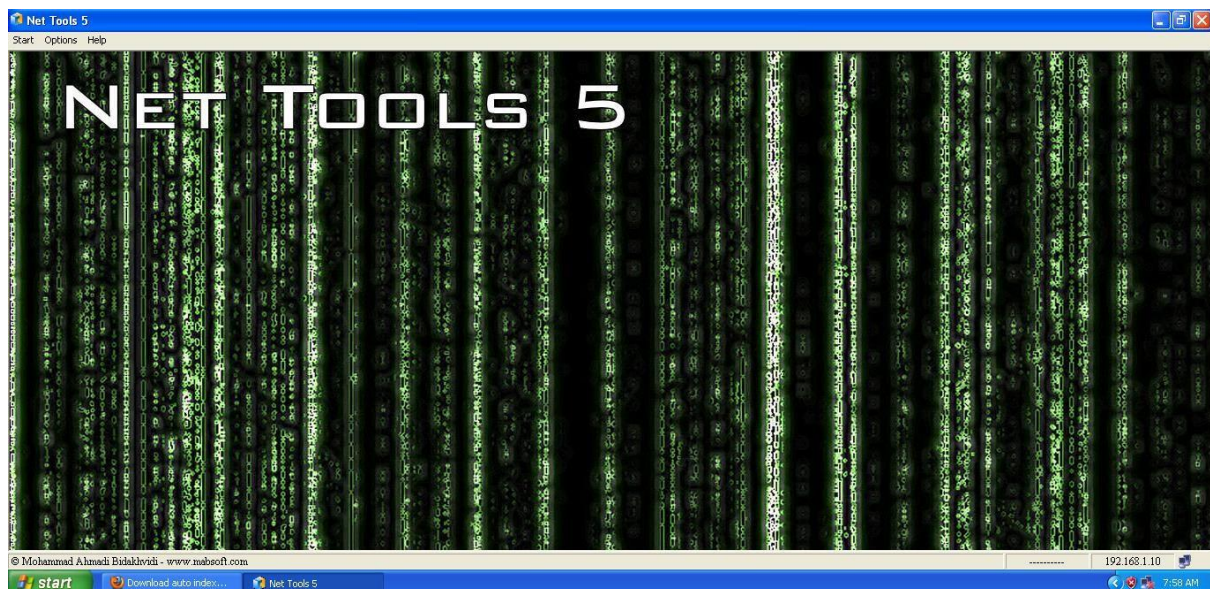
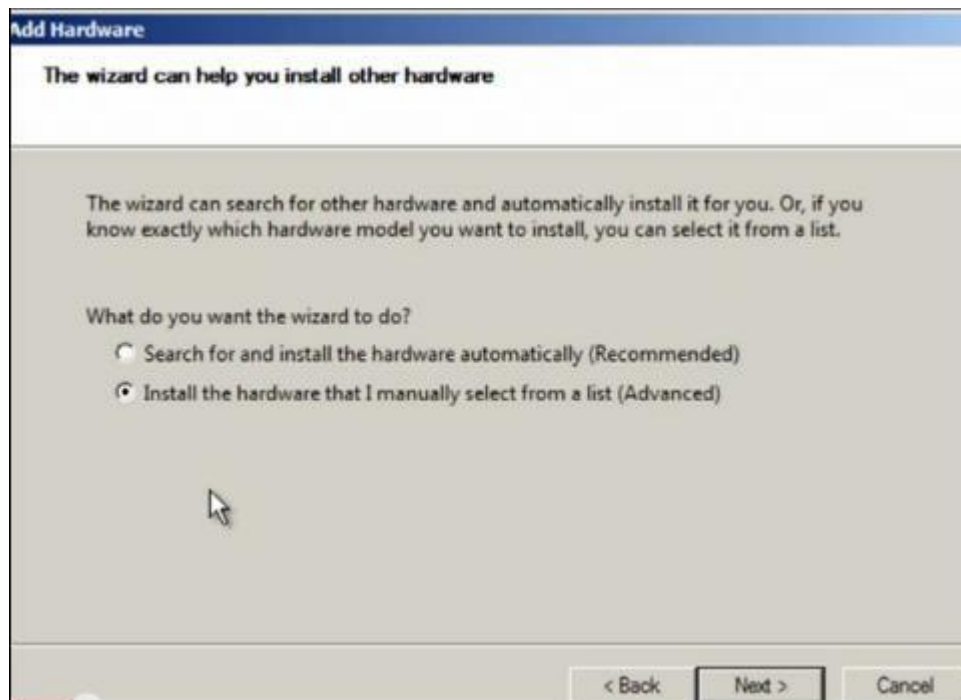


Image 4: This represents the Net Tools, which is installed and running on Virtual XP.

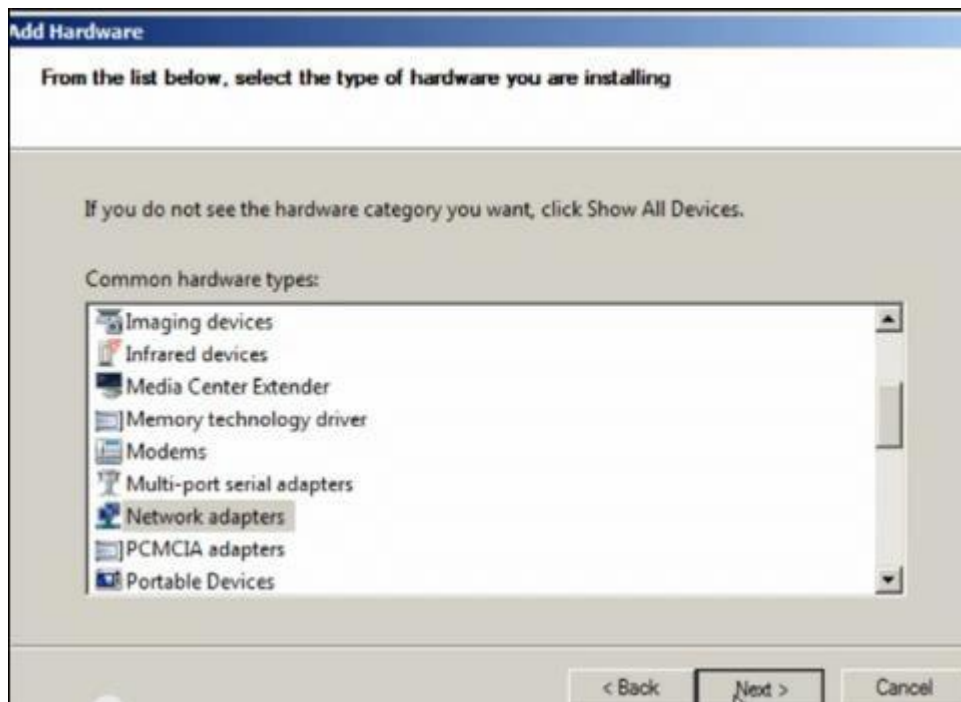
Step 4:

Now, we will setup the devices required to simulate a DOS attack, in the GNS3 software.

- a) Setup a Microsoft loopback adapter in Windows XP and assign a public IP address to this. This virtual XP will act as the attacker PC from the internet.
- b) To create a loopback adapter, the first step is to go to command prompt and type the command “hdwwiz.exe”, this is the shortest way to add a new hardware.



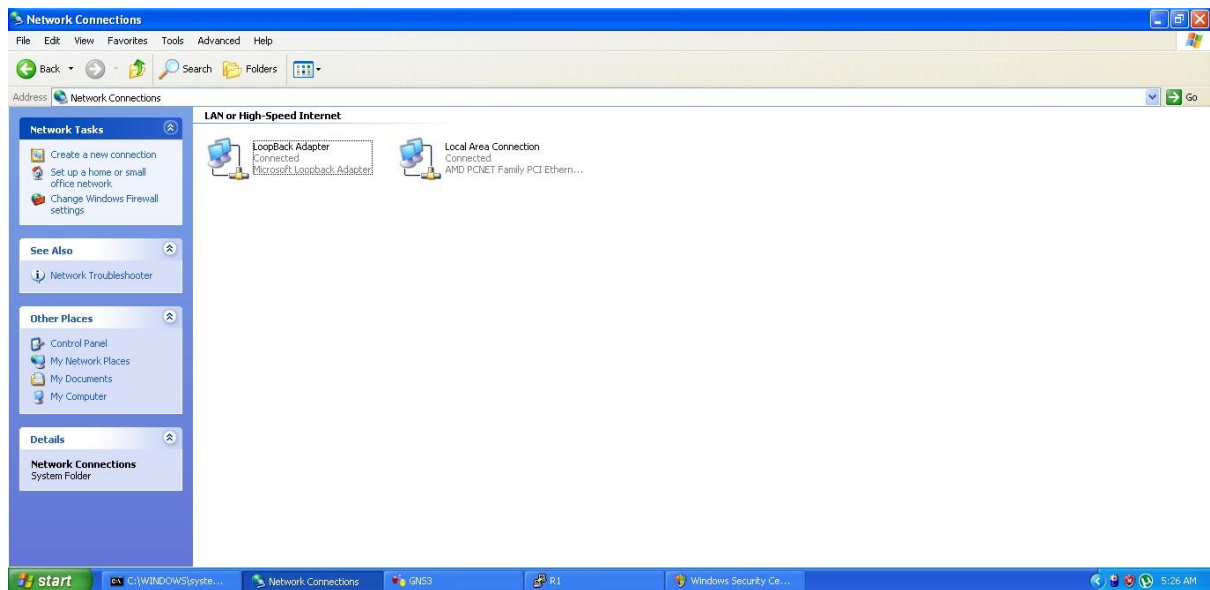
- c) Now the “Add new hardware” wizard will come up and select the second option which says, “Install the hardware manually”, as shown in the above image.



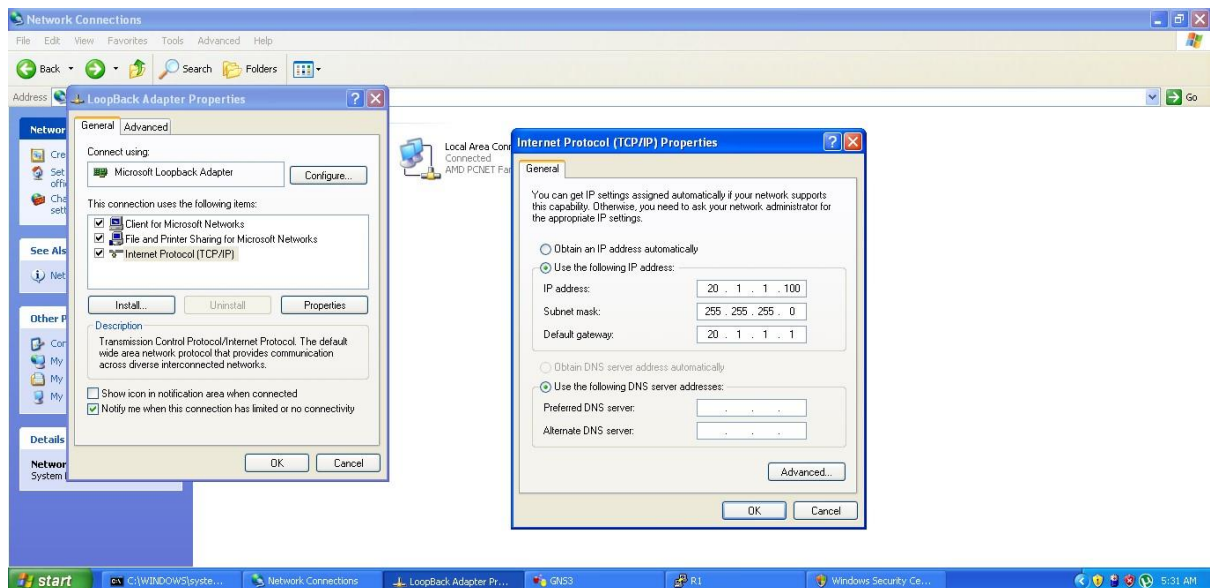
- d) On the next screen, please select “Network Adapters”, from the hardware list, as shown in the above image.



- e) On the next screen, please select “Microsoft” from the vendor list and “Microsoft Loopback Adapter” from the Network adapter list as shown in the above image.
- f) Now Microsoft loopback adapter is added to windows XP, and this can be viewed under Network Connections in Control panel, as seen in the below image.

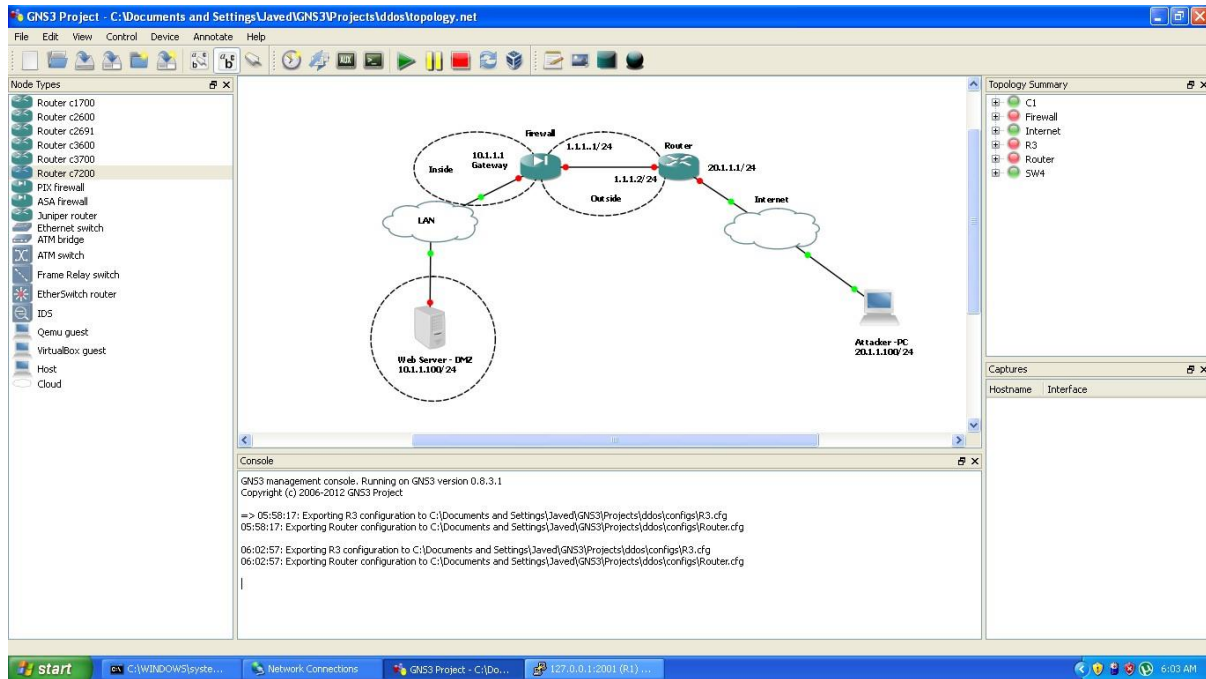


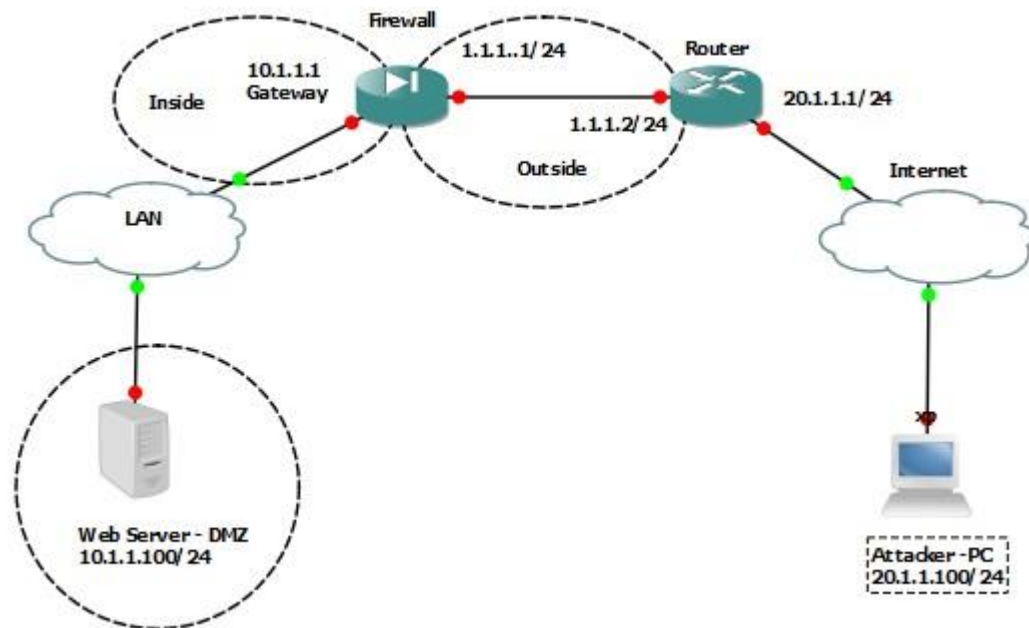
- g) Next step is to configure an ip address to this loopback adapter, so that this adapter can be connected to one of the routers in the simulated internet cloud in GNS3. At this point we have to make sure that the Loopback adapter's ip address should be something in the public IP range and the interface of the router which is pointing towards the internet should be in the “same”, public IP range.
- h) Let us configure the loopback adapter's ip address as 20.1.1.100/24 and set the default gateway as 20.1.1.1 as shown in the below image.



- i) The above configuration means that the virtual XP can also be access by the ip address 20.1.1.100 and the default gateway i.e. router's interface which is connecting to the switch has an ip address of 20.1.1.1.

- j) In the next step, we are going to create a topology, through which we can simulate the DOS attack, after we create the topology, we have to connect our virtual XP to the topology, which actually represents the internet cloud, a server placed in the DMZ of a corporate (in actual configuration it is placed in Inside zone) and the attacker PC in the internet (i.e. the virtual XP). Between the internet(outside) and the Corporate LAN, we have placed an ASA(Adaptive security Appliance) version 8.4, which has all the functionalities of a firewall and features like NAT, Routing, VPN, AAA services etc. hence it is called UTM(Unified Threat Management) device. The topology which we are going to use for the DOS simulation is in the below image.





Configuration:

a) Web Server –

IP address: 10.1.1.100/24

Zone: Inside

Device: Router c7200 used as a web server.

Running configuration of this device:

```

version      12.2      interface
FastEthernet0/0  ip    address
10.1.1.100 255.255.255.0 speed auto
duplex auto ip http server no ip http
secure-server
ip route 0.0.0.0 0.0.0.0 10.1.1.1

```

b) Firewall – IP

address :

Inside zone interface - 10.1.1.1 (which acts as gateway for LAN users)

Outside zone interface – 1.1.1.1

Access-lists:

Configuration before DOS security on firewall

ASA Version 8.4(2)

!

hostname ciscoasa enable password

8Ry2YjIyt7RRXU24 encrypted passwd

2KFQnbNIdL2KYOU encrypted names

!

interface GigabitEthernet0

nameif outside security-level 0

ip address 1.1.1.1 255.255.255.0

!

interface GigabitEthernet1 nameif inside

security-level 100 ip address 10.1.1.1

255.255.255.0 access-list out-in extended permit

icmp any any access-group out-in in interface

outside

route outside 0.0.0.0 0.0.0.0 1.1.1.2 1

c) Gateway router for attacker PC:

Ip address –

Interface towards firewall – 1.1.1.2/24

Interface towards attacker PC – 20.1.1.1/24

Configuration –

```
interface FastEthernet0/0  ip
address 1.1.1.2 255.255.255.0
duplex auto speed auto
!
interface FastEthernet0/1  ip
address 20.1.1.1 255.255.255.0
duplex auto speed auto
!
ip forward-protocol nd ip route
10.1.1.0 255.255.255.0 1.1.1.1 no ip
http server
no ip http secure-server
```

Attacker PC:

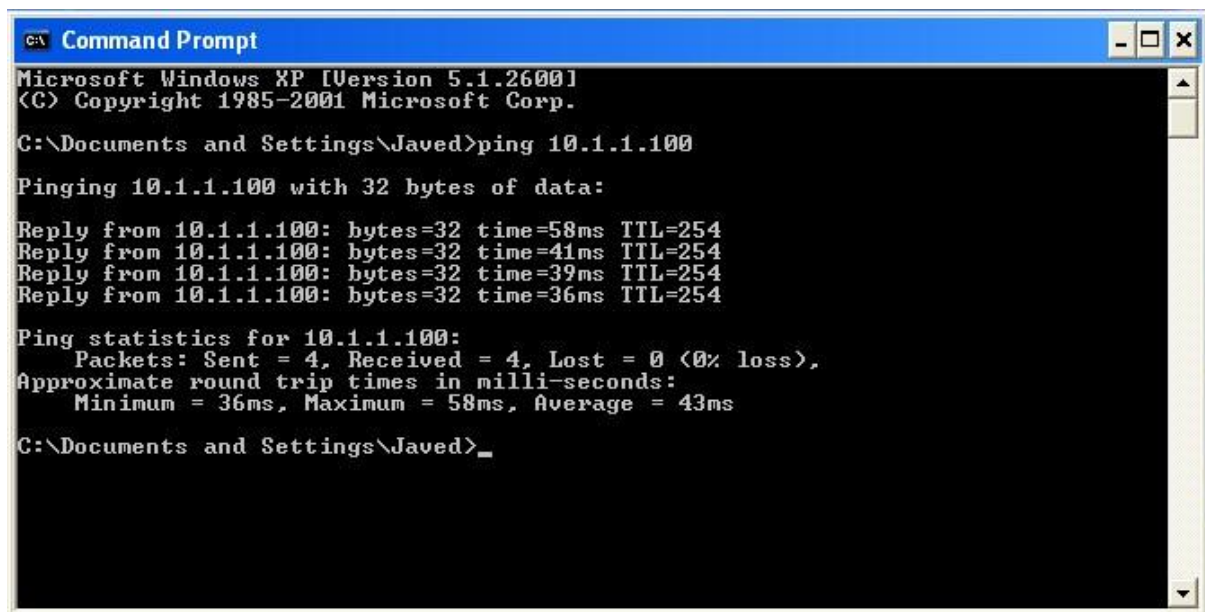
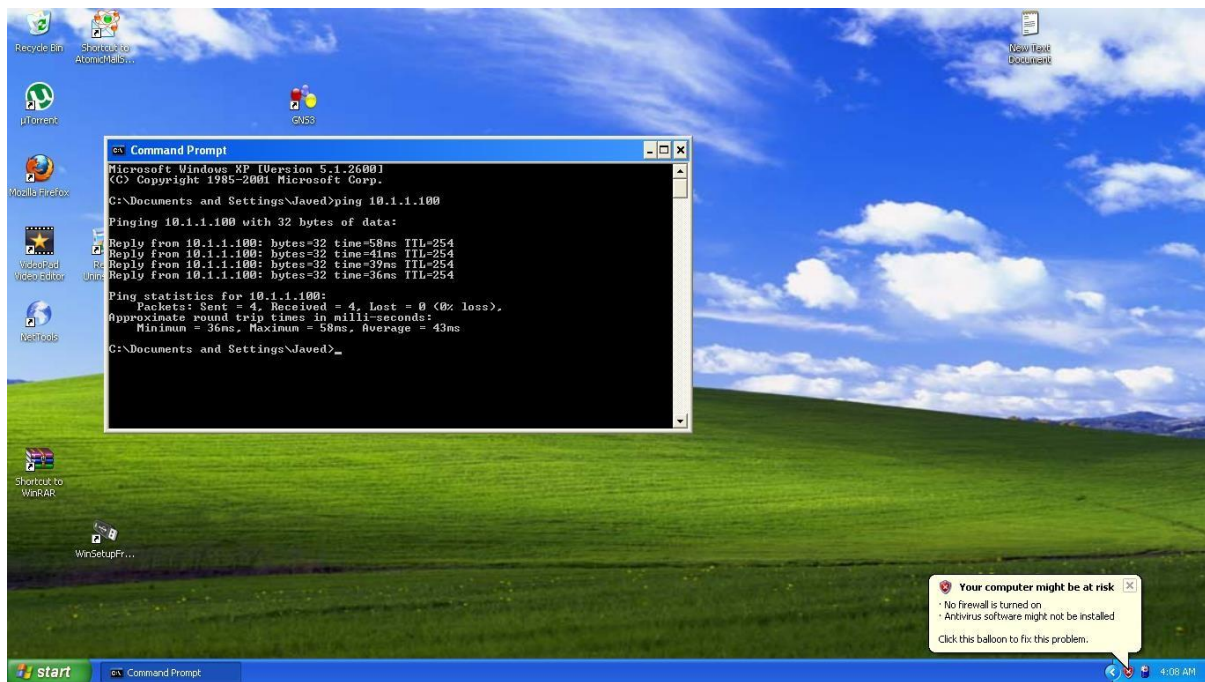
Ip address – 20.1.1.100/24

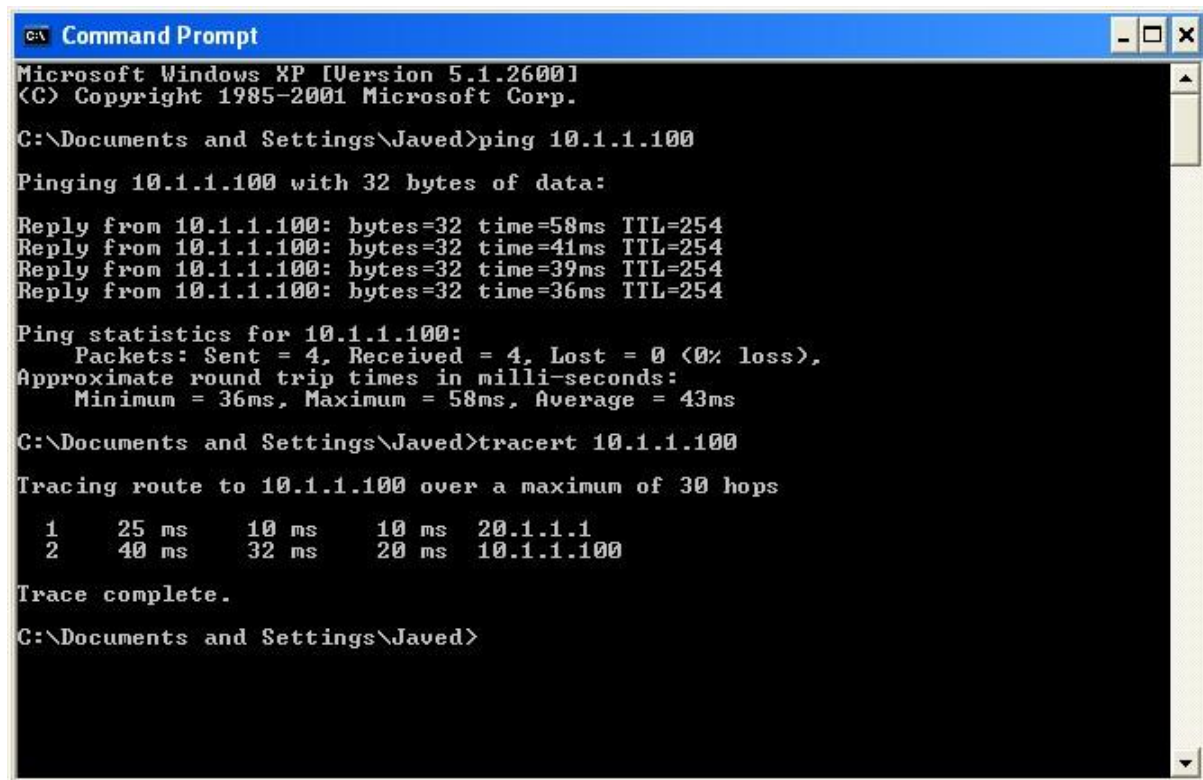
Operating system – Windows XP – SP3

Location - Internet

Connectivity Tests:

Now that we have all the devices setup and connected, we should test whether the attacker PC can actually reach the web server, after all if there is no reachability, the DOS attack is not possible. We can find this using a simple and trace route test, as shown in the below images.





```
C:\ Command Prompt
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Documents and Settings\Javed>ping 10.1.1.100

Pinging 10.1.1.100 with 32 bytes of data:

Reply from 10.1.1.100: bytes=32 time=58ms TTL=254
Reply from 10.1.1.100: bytes=32 time=41ms TTL=254
Reply from 10.1.1.100: bytes=32 time=39ms TTL=254
Reply from 10.1.1.100: bytes=32 time=36ms TTL=254

Ping statistics for 10.1.1.100:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 36ms, Maximum = 58ms, Average = 43ms

C:\Documents and Settings\Javed>tracert 10.1.1.100

Tracing route to 10.1.1.100 over a maximum of 30 hops

  1    25 ms    10 ms    10 ms    20.1.1.1
  2    40 ms    32 ms    20 ms    10.1.1.100

Trace complete.

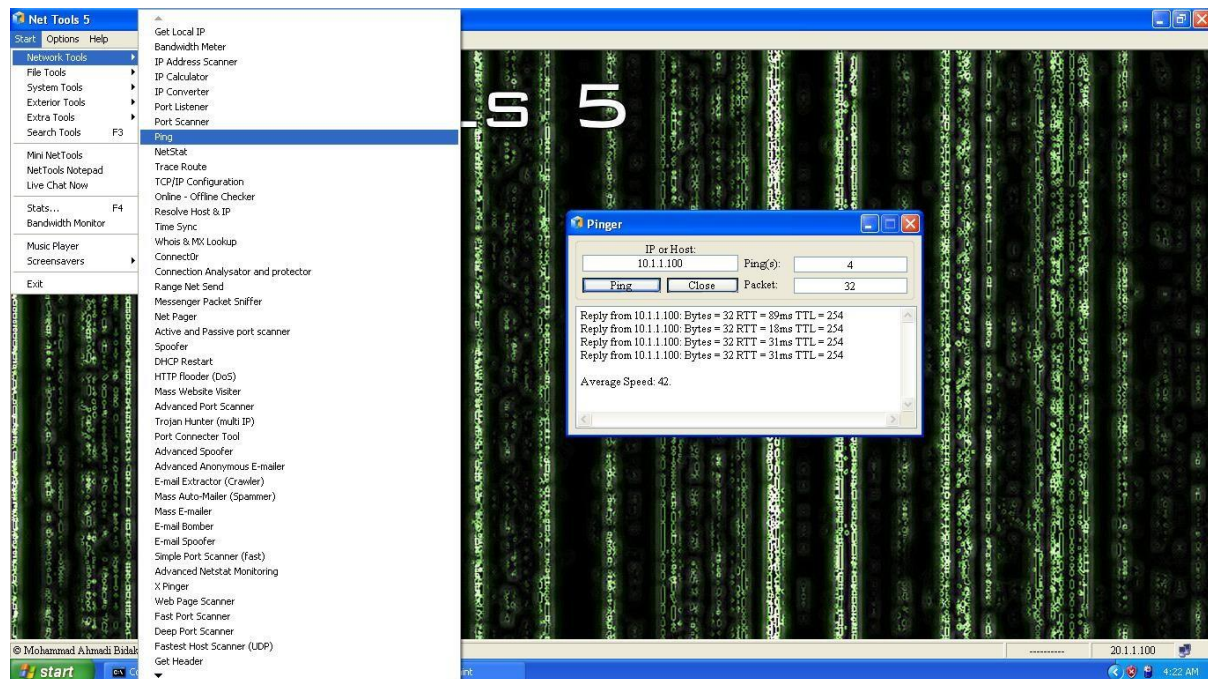
C:\Documents and Settings\Javed>
```

By the above images, we can find that, the attacker pc has access network reachability to the webserver from the internet.

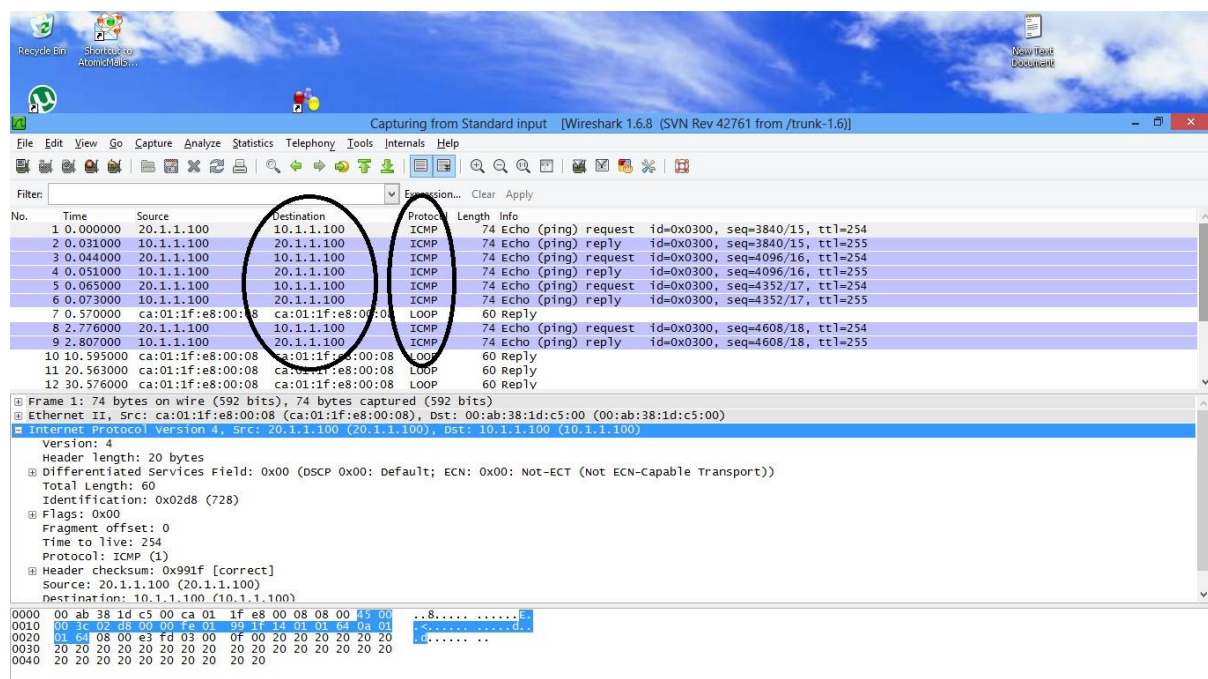
Launch of the attack on webserver using Net tools:

In our simulation task we use Net tools 5, which is a network monitoring tool and a hacking tool as well.

In the first step, we will check whether the Net tools is able to ping the webserver, by going into network tools -> ping option, as shown in the below image.

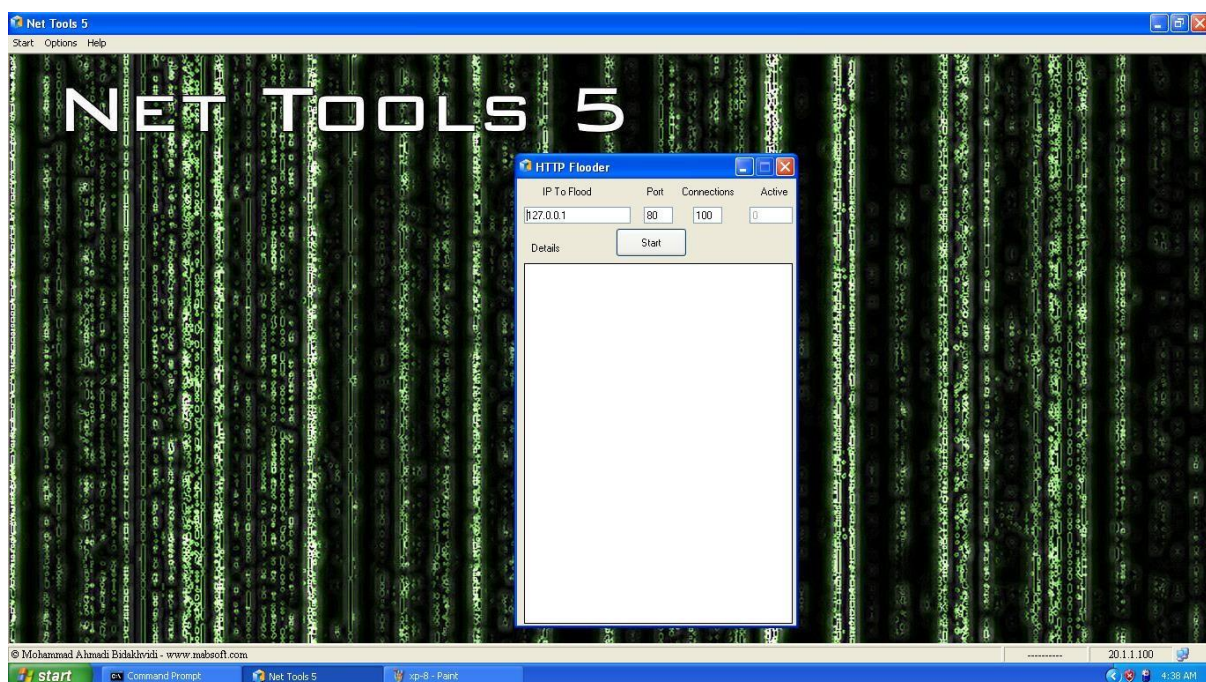
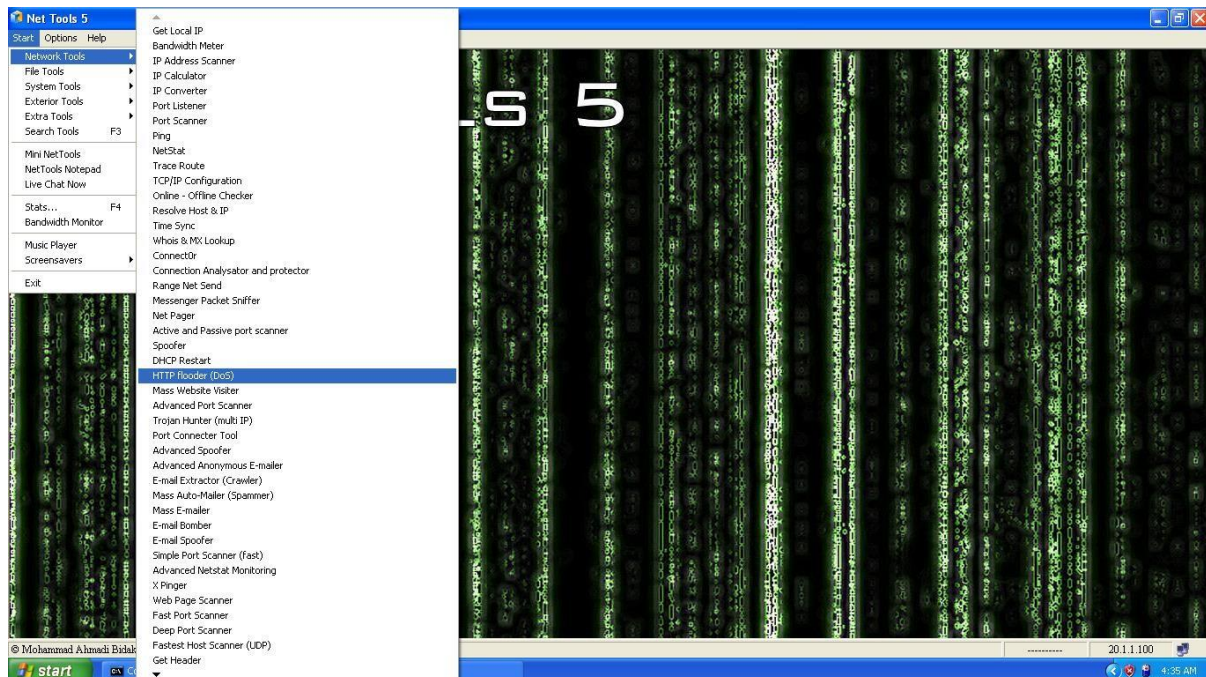


We can verify that the software is able to send successful ICMP packets to the web server. This is possible, as we have opened an access control list (ACL) in the firewall which allows any ICMP packets from the internet to the LAN or DMZ. We will analyze what is happening during the Ping, at the packet level using Wireshark.

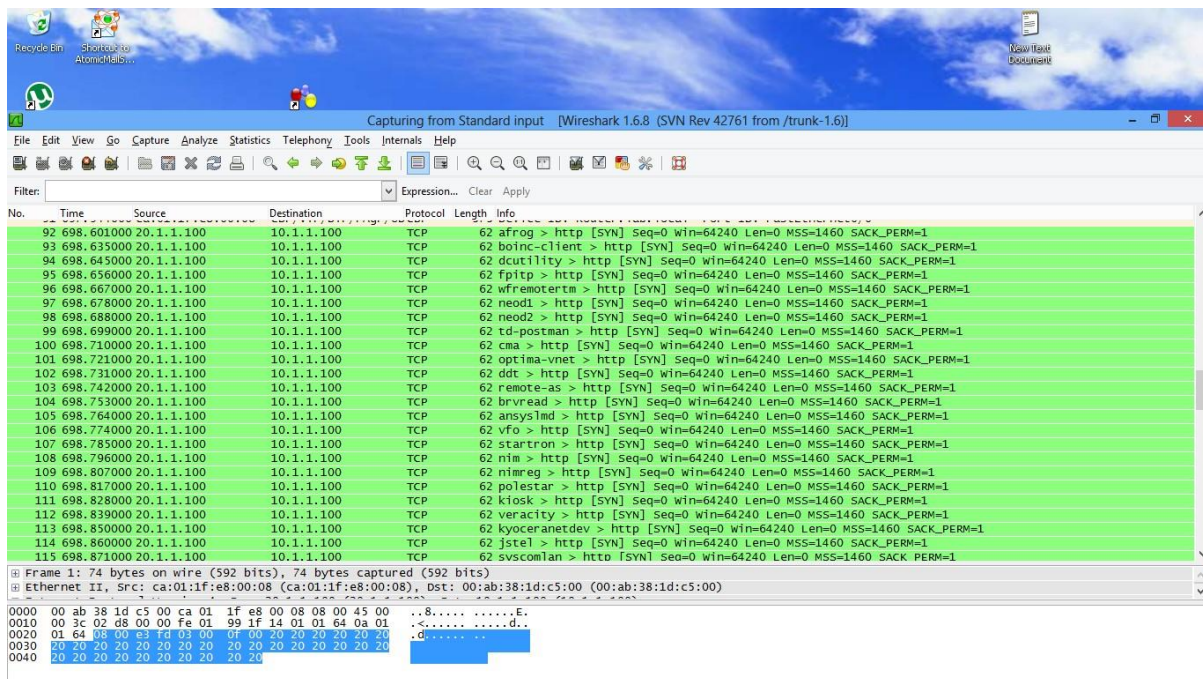


As we can see, four ICMP packets have been sent from the source 20.1.1.100 to destination 10.1.1.100 (web server) and the ping is successful. We can also observe that all the 4 packets we sent and received from the internet to the web server in 2 seconds.

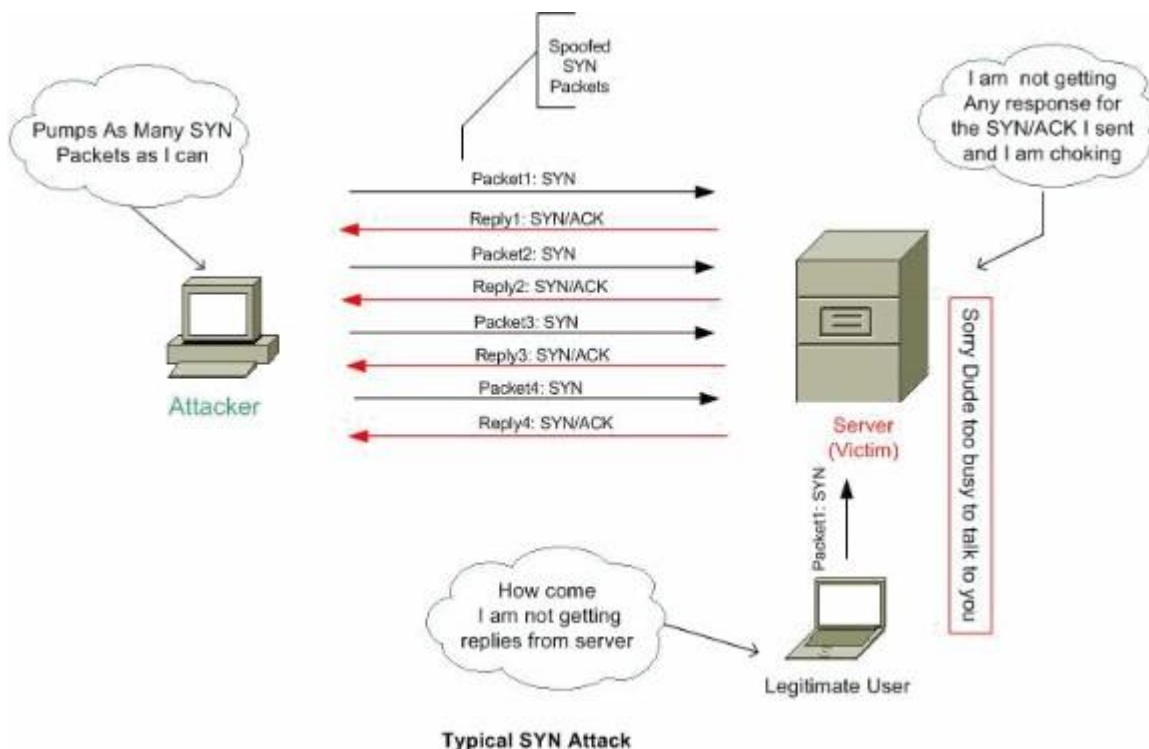
In the next step we are going to deliver the DOS attack on the server, without enabling DOS security on the firewall. To create the DOS attack, first we need to go to Network tools and Http flooder (DOS) in the NetTools, as shown in the below image.



In our case we need to give 10.1.1.100 as the Ip to flood instead of 127.0.0.1. As soon as we hit the start button, the web server is under DOS attack as seen in the below Wireshark analysis.



As we can observe that hundreds of syn packets from the source 20.1.1.100 are flooded to destination 10.1.1.100 in less than “one” second. The below image from Cisco’s website, clearly elaborates, what happens in a typical syn flood attack, which represents the above Wireshark capture.

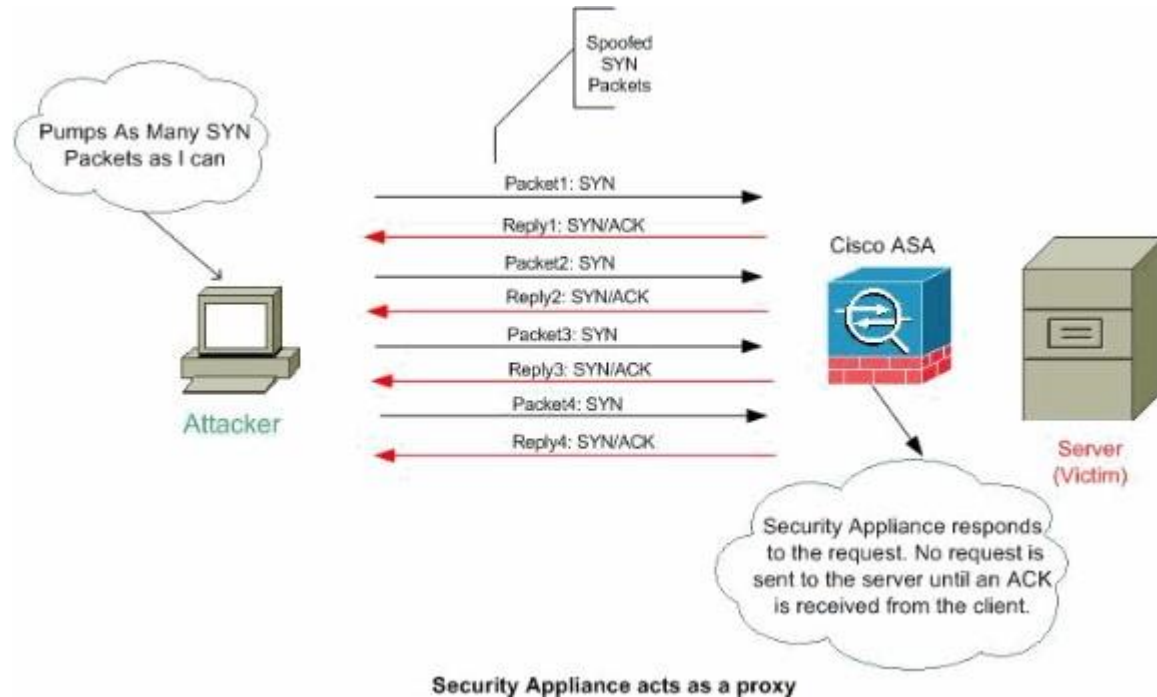


The description of each packet says it is a “SYN” packet, that means it is a half open connection, without the TCP 3-way handshake. With these SYN packets, a certain amount of buffer is allocated for each SYN packet and in less than a minute all the server resources are allocated to

these half open connections and the servers failed to respond to genuine queries, stating that it is under Denial Of Service (DOS) attack.

Mitigation techniques:

As we have already discussed, a Cisco ASA firewall can be very helpful in mitigating and stopping DOS attacks on LAN or DMZ servers.



The above image from Cisco's website, describes how ASA firewall stop syn flood attacks can. In this process we will limit the number of "embryonic" or "half open connections" a client can have. If the embryonic connection limit is reached, then the security appliance responds to every SYN packet sent to the server with a SYN+ACK and does not pass the SYN packet to the internal server. If the external device responds with an ACK packet, then the security appliance knows it is a valid request (and not part of a potential SYN attack). The security appliance then establishes a connection with the server and joins the connections together. If the security appliance does not get an ACK back from the server, it aggressively times out that embryonic connection.

In this scenario we have used Modular Policy Framework, which limits number of half open connections to the server and thus stops DOS attack.

We have used the below configuration in the Firewall to stop half open connections, which will have a maximum of "100" open connections, a maximum of "200" embryonic connections, and a maximum of "10" embryonic connections from a particular client (identified by an IP address). Furthermore, we have set connection timeout timer for a normal connection as 2 hours, timeout for embryonic connections as "45" seconds and "25" minutes for a half closed connection.

```
Firewall(config)#class-map tcp_syn
```

```
Firewall(config-cmap)#match port tcp eq 80
```

[View My UpWork Profile Here](#)

```
Firewall(config-cmap)#exit
```

```
Firewall(config)#policy-map tcpmap
```

```
Firewall(config-pmap)#class tcp_syn
```

```
Firewall(config-pmap-c)#set connection conn-max 100
```

```
Firewall(config-pmap-c)#set connection embryonic-conn-max 200
```

```
Firewall(config-pmap-c)#set connection per-client-embryonic-max 10
```

```
Firewall(config-pmap-c)#set connection per-client-max 5
```

```
Firewall(config-pmap-c)#set connection random-sequence-number enable
```

```
Firewall(config-pmap-c)#set connection timeout embryonic 0:0:45
```

```
Firewall(config-pmap-c)#set connection timeout half-closed 0:25:0
```

```
Firewall(config-pmap-c)#set connection timeout tcp 2:0:0
```

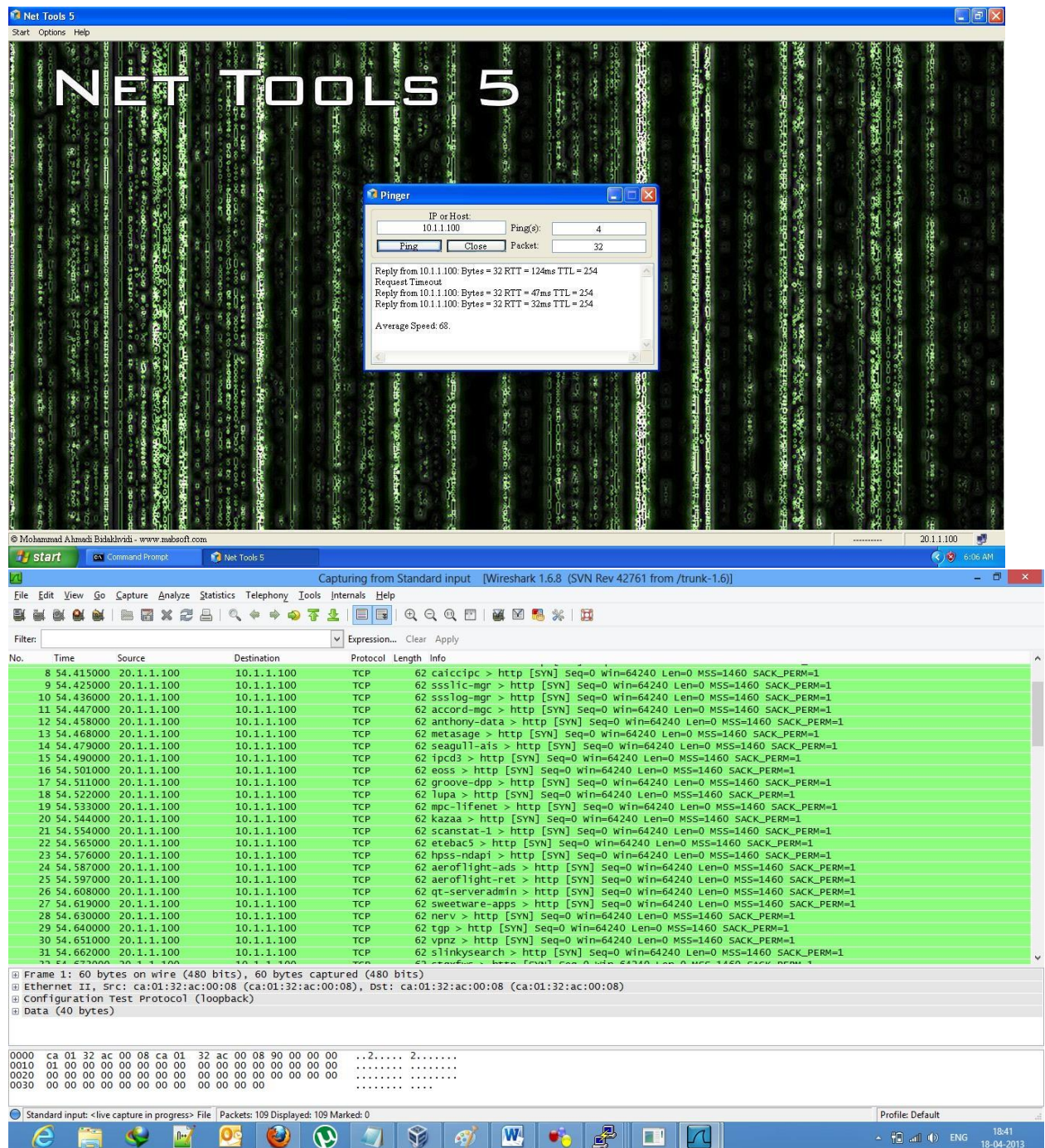
```
Firewall(config-pmap-c)#exit
```

```
Firewall(config-pmap)#exit
```

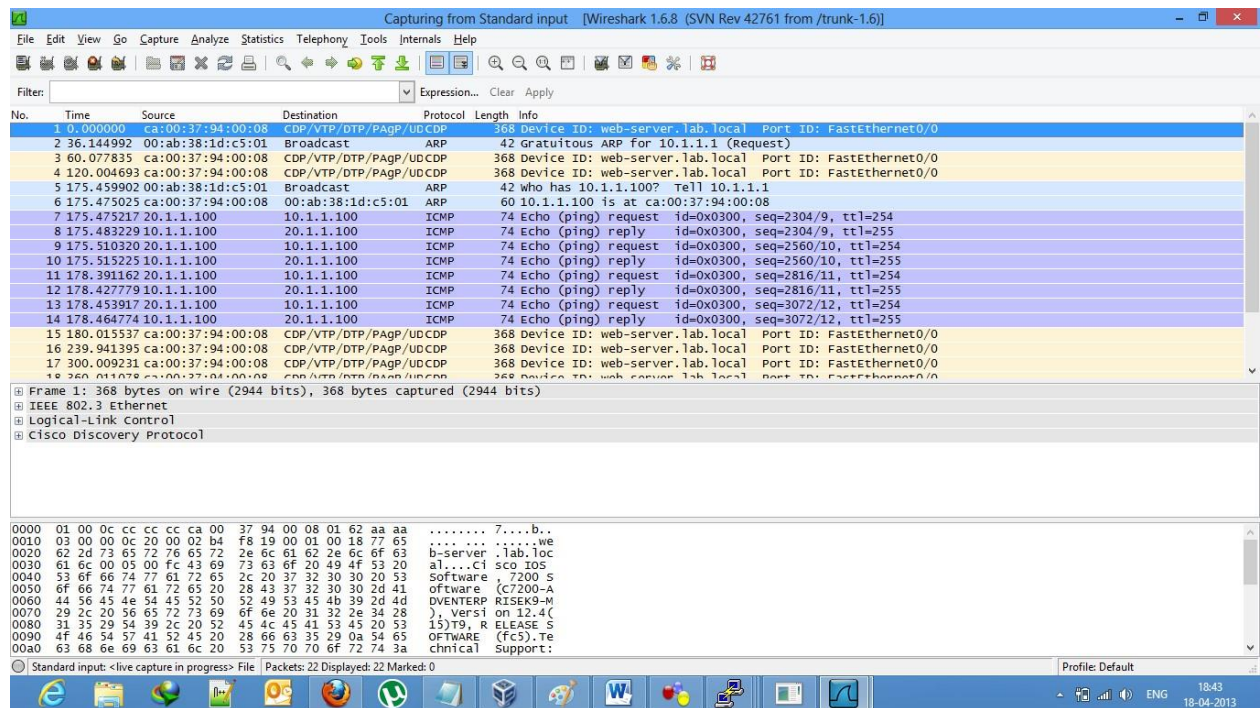
```
Firewall(config)#service-policy tcpmap global
```

Now we will run a DOS attack on the server after the security is enabled and check what will be Wireshark output.

The below image shows that the attacker PC is still able to ping the web server, after we have enabled DOS security, but it is able to ping because, this is a normal ping.



The above image represents the Wireshark capture between the Internet router and the firewall, which clearly shows that syn flood attack is happening from source 20.1.1.100 to destination 10.1.1.100, and we can see hundreds of packets flooding 10.1.1.100 in less than a second.



At the same time the above image shows the Wireshark capture between the firewall and web server, which clearly explains that all the syn-flood packets have been dropped by the firewall as soon as they reach it. At the same time, we can observe normal ping packets which came from the attacker pc which have been passed by the firewall.

Inference: The above simulation experiment shows that the firewall before the corporate network has stopped one of the most common attacks over servers, i.e. the DOS attack, using Modular Policy Framework, which can be used to define interesting traffic and the actions to be taken on that traffic.